HANDOUT — AULA 11.1

O Prontuário da LojaRevisao

Revisão das Aulas 01 a 11 — Arquitetura de Aplicações Web

🎯 MISSÃO

A LojaRevisao vai ao ar na sexta-feira, e vocês são a auditoria. Há 11 reclamações, cada uma nascida de uma aula diferente. Corrijam a API e registrem o que aprenderam.

- Parte 1, durante a prática — Preencham o diário de correção
- Parte 2, em casa — Relacionem cada sintoma à aula de origem e ao conceito violado, sem consulta
- Parte 3, em casa — Respondam às 3 perguntas que cruzam mais de uma aula

⏱️ *Parte 1: 75 minutos | 👥 Formato: em duplas | Partes 2 e 3: errar sem consulta mostra o que estudar.*

Nomes: Miguel Ribeiro Muniz Morais Turma: Quinta-feira noite Data: 06/11/2026

PARTE 01 — Diário de correção (durante a prática)

Corrijam na ordem. A cada falha, reiniciem a API, rodem a pasta da falha no Postman e registrem a regra em uma frase.

Falha	Aula	A regra que estava sendo violada, em uma frase	Verde?
01	01	Pedidos mexia direto no estoque do Catálogo. Tem que passar pelo ICatalogo, que é onde está a regra.	☒
02	02	Status code errado. Produto que não existe é 404 e criar é 201, não 200.	☒
03	03	GET não pode alterar nada e verbo não vai na URL. Cancelar é DELETE /pedidos/{id}.	☒
04	04	Faltava paginação. Tem que limitar no servidor.	☒
05	05	Pedido tem que ser tudo ou nada. Um SaveChanges só no final.	☒
06	06	Não precisa esperar o e-mail. Joga um evento na fila e responde na hora.	☒

Falha	Aula	A regra que estava sendo violada, em uma frase	Verde?
07	07	Nunca concatenar o que o usuário digita no SQL.	☒
08	08	Token vencido não pode passar. Faltava validar a expiração.	☒
09	09	Estar logado não basta: só Admin apaga produto e só o dono vê o pedido.	☒
10	10	Swagger tem que bater com a API: 201, os erros e o botão de token.	☒
11	11	O teste copiou o erro do código. O esperado vem da regra (>= 300).	☒ Postman ☒ dotnet test

PARTE 02 — Sintoma, aula e conceito (em casa)

As aulas: 01 Monólito e Microsserviços · 02 REST: Fundamentos · 03 REST: Design de APIs · 04 REST: Revisão · 05 Persistência · 06 Comunicação entre Serviços · 07 Segurança (OWASP) · 08 AuthN e AuthZ · 09 RBAC, ABAC e PBAC · 10 OpenAPI · 11 Testes.

#	Sintoma relatado	Aula	Conceito violado
A	Cada compra demora mais de 3 segundos. O log mostra o sistema esperando o provedor de e-mail responder.	06	Comunicação síncrona (acoplamento temporal)
B	O app abre uma tela vazia: para um produto que não existe, a API responde 200 com {"erro": "..."} no corpo.	02	Status code errado (devia ser 404)
C	João abriu o pedido da Maria trocando o número na URL. E um Cliente conseguiu apagar produtos do catálogo.	09	Autorização: RBAC e ABAC
D	A tela de produtos mostra 10 itens, mas baixa 2.000 registros a cada abertura.	04	Falta de paginação
E	Quem compra exatamente R$ 300,00 paga frete, embora a regra diga “grátis a partir de R$ 300,00”. Os testes estão todos verdes.	11	Teste de borda mal feito
F	Um pedido de 999.999 unidades foi aceito e o estoque ficou negativo. A regra existe no Catálogo, mas os Pedidos alteram a tabela dele diretamente.	01	Fronteira entre módulos
G	Um token vencido há 5 minutos continua abrindo a API.	08	Não valida expiração do JWT
H	O robô de um buscador passou pelo site e vários pedidos foram cancelados. A rota: GET /api/v1/cancelarPedido?id=7.	03	GET alterando dados / verbo na URI
I	Um pedido com um item válido e outro inexistente devolve erro, mas o estoque do item válido baixou.	05	Atomicidade (ACID)
J	O time parceiro reclama: o Swagger diz que o POST devolve 200, ele devolve 201, e não há onde informar o token.	10	Contrato OpenAPI errado
K	Alguém digitou %' OR '1'='1 na busca, e a loja listou o catálogo inteiro.	07	SQL Injection

PARTE 03 — Perguntas que cruzam aulas (em casa)

1. Sintoma I: se o Catálogo fosse outro serviço, com banco próprio, a correção continuaria simples? Por quê?

Como é o mesmo banco, então um SaveChanges só resolve. Com bancos separados não dá pra fazer uma transação única. Se der erro no meio, desfazer o que já foi feito.

---

2. O sintoma C esconde duas falhas. Uma se resolve com papel; a outra, não. Qual é qual, e por quê?

Apagar produto se resolve com papel (só admin pode). Ver o pedido da Maria não, porque o João também é Cliente. Aí tem que olhar qual o dono do pedido.

---

3. Sintoma E: como uma suíte pode estar toda verde com um bug no código? Que cuidado foi esquecido?

O teste esperava o valor errado. Faltou testar a borda pela regra e ver o teste falhar antes de arrumar o código.

🏆 **DESAFIO**

1. Se a sexta-feira chegasse e só desse tempo de corrigir 3 das 11 falhas, quais seriam? Justifiquem pelo dano em produção.

1) Falha 07 (SQL Injection): qualquer um consegue ler ou alterar o banco.

2) Falha 09 (RBAC/ABAC): cliente apaga produto e vê pedido dos outros.

3) Falha 08 (token vencido): um token ia valer pra sempre.